API Contract PCOSmart v1.0

Kontrak antara Frontend dan Backend · Selaras dengan PRD v1.0 · Pemilik: Backend (PM) · Perubahan hanya lewat PR (lihat Bagian 13)

1. Gambaran

Backend PCOSmart adalah **Supabase**. Frontend berkomunikasi lewat dua jalur:

- **Jalur A, akses data langsung** dengan `supabase-js`. Dilindungi Row Level Security (RLS), jadi setiap pengguna hanya bisa menyentuh barisnya sendiri. Dipakai untuk profil, check-in, edukasi, dan membaca riwayat chat.
- **Jalur B, Edge Functions** untuk logika yang tidak boleh berjalan di browser: `chat` (memanggil Gemini dengan API key rahasia) dan `delete-account` (butuh hak admin).

Semua operasi, kecuali daftar dan login, membutuhkan pengguna yang sudah masuk.

Area	Jalur	Pemilik BE	Pengguna di FE
Auth, onboarding, profil	A	BE	FE-A (auth), FE-B (onboarding, profil)
Check-in harian	A	BE	FE-B
Chatbot	B (`chat`) + A (baca riwayat)	BE	FE-A
Edukasi	A	BE	FE-B
Ekspor dan hapus data	A + B (`delete-account`)	BE	FE-B

Sumber kebenaran: dokumen ini. Jika kode dan dokumen berbeda, salah satunya harus diperbaiki lewat PR, jangan dibiarkan.

2. Konvensi Umum

Hal	Aturan
Base URL	`https://<PROJECT_REF>.supabase.co` (FE membacanya dari `VITE_SUPABASE_URL`)
Autentikasi	Supabase Auth email + kata sandi. `supabase-js` mengirim token otomatis, termasuk pada `functions.invoke`
Format data	JSON, UTF-8, field `snake_case`
ID	UUID
Tanggal check-in	`checkin_date` berformat `YYYY-MM-DD`, memakai **tanggal lokal pengguna (WIB)**, dan **selalu dikirim eksplisit oleh FE**. Default `current_date` di database memakai UTC sehingga bisa salah hari
Timestamp	ISO 8601, UTC
Bahasa teks	Indonesia

2.1 Format error Edge Function

```
{
  "error": {
    "code": "RATE_LIMITED",
    "message": "Pesan ramah yang boleh langsung ditampilkan.",
    "retry_after_seconds": 1200
  }
}
```

`code` dipakai untuk logika FE, `message` boleh langsung ditampilkan ke pengguna, `retry_after_seconds` hanya ada bila relevan.

HTTP	code	Arti	Perilaku FE
400	`VALIDATION_ERROR`	Input tidak valid	Tampilkan pesan, jangan retry otomatis

HTTP	code	Arti	Perilaku FE
401	`UNAUTHENTICATED`	Token tidak ada atau kedaluwarsa	Arahkan ke login
403	`CONSENT_REQUIRED`	Onboarding dan consent belum selesai	Arahkan ke onboarding
429	`RATE_LIMITED`	Melebihi batas pesan	Tampilkan "coba lagi sebentar", nonaktifkan tombol kirim sampai waktu retry
503	`LLM_UNAVAILABLE`	Gemini gagal atau kuota habis	Tampilkan "asisten sedang sibuk" dan tombol coba lagi; teks tetap ada di input
500	`INTERNAL`	Kesalahan server	Tampilkan pesan umum dan tombol coba lagi

Error Jalur A memakai bentuk `{ data, error }` bawaan `supabase-js`. FE menampilkan pesan umum yang ramah dan tidak menampilkan `error.message` mentah ke pengguna.

3. Nilai Enum (disepakati)

Nama	Nilai (slug)	Label UI
`age_range`	`15-17`, `18-24`, `25-34`, `35-44`	sama
`period_intensity`	`ringan`, `sedang`, `deras`	Ringan, Sedang, Deras
`symptoms`	`nyeri_perut`, `jerawat`, `rambut_rontok`, `rambut_berlebih`, `lelah`, `cemas`, `kembung`, `sulit_tidur`	Nyeri perut, Jerawat, Rambut rontok, Rambut tumbuh berlebih, Lelah, Cemas, Kembung, Sulit tidur
`role`	`user`, `model`	tidak ditampilkan
`flag.level`	`none`, `warning`, `severe`, `crisis`	tidak ditampilkan
`beban`	`ringan`, `sedang`, `normal`	Ringan, Sedang, Normal
`category` artikel	`apa_itu_pcos`, `makanan`, `aktivitas_fisik`, `tidur_stres`, `kapan_ke_dokter`	Apa itu PCOS, Makanan, Aktivitas fisik, Tidur dan stres, Kapan ke dokter

Backend hanya mengirim dan menerima **slug**. FE menyimpan pemetaan slug ke label di satu file (`src/config/labels.js`).

4. Autentikasi dan Profil (Jalur A)

```
// Daftar
const { data, error } = await supabase.auth.signUp({
  email, password,
  options: { data: { nickname } },
});
// Jika 'Confirm email' aktif, data.session = null → tampilkan 'Cek emailmu'.

// Login, logout, sesi
await supabase.auth.signInWithPassword({ email, password });
await supabase.auth.signOut();
supabase.auth.onAuthStateChange((event, session) => { /* perbarui state */
});
```

Menyelesaikan onboarding:

```
const { error } = await supabase.from('profiles').upsert({
  id: user.id,
  nickname,                          // 2-30 karakter
  age_range,                         // enum
  consent_at: new Date().toISOString(),
});
```

Aturan guard routing: pengguna dianggap selesai onboarding jika baris `profiles` ada dan `consent_at` tidak null. Jika belum, semua route kecuali `/onboarding` diarahkan ke `/onboarding`.

Ambil dan ubah profil:

```
await supabase.from('profiles')
  .select('id, nickname, age_range, consent_at')
  .eq('id', user.id).maybeSingle();

await supabase.from('profiles').update({ nickname }).eq('id', user.id);
```

Validasi sisi klien: email valid, kata sandi minimal 8 karakter, nickname 2-30 karakter.

5. Check-in Harian (Jalur A)

Field	Tipe	Wajib	Aturan
`id`	uuid	server	dibuat otomatis
`user_id`	uuid	ya (untuk upsert)	sama dengan id pengguna yang login
`checkin_date`	string `YYYY-MM-DD`	ya	tanggal lokal; unik per pengguna
`on_period`	boolean	ya	
`period_intensity`	enum atau null	tidak	harus null jika `on_period` false
`symptoms`	array string	ya	boleh kosong; nilai dari enum
`energy`	integer 1-5	ya	
`mood`	integer 1-5	ya	

Field	Tipe	Wajib	Aturan
`sleep_hours`	number atau null	tidak	0-24, kelipatan 0.5
`notes`	string atau null	tidak	maksimal 500 karakter
`created_at`	timestamp	server	

```
// Simpan atau perbarui check-in (satu per hari)
await supabase.from('daily_checkins').upsert(
  {
    user_id: user.id, checkin_date: '2026-11-10',
    on_period: false, period_intensity: null,
    symptoms: ['lelah', 'cemas'], energy: 2, mood: 3,
    sleep_hours: 5.5, notes: null,
  },
  { onConflict: 'user_id,checkin_date' }
).select().single();

// Ambil check-in hari ini (data = null jika belum ada, bukan error)
await supabase.from('daily_checkins').select('*')
  .eq('checkin_date', today).maybeSingle();

// Ambil rentang (maksimal 90 hari)
await supabase.from('daily_checkins').select('*')
  .gte('checkin_date', fromDate).lte('checkin_date', toDate)
  .order('checkin_date', { ascending: true });
```

`user_id` wajib ikut dikirim saat upsert agar konflik terdeteksi. RLS memastikan pengguna hanya bisa memakai id miliknya sendiri.

6. Chatbot

6.1 Kirim pesan: `POST /functions/v1/chat`

Request

```
{
  "message": "Aku capek banget hari ini",
  "mode": "free",
  "context_article_id": null,
  "tasks": []
}
```

Field	Tipe	Wajib	Aturan
`message`	string	ya	1-1000 karakter setelah trim
`mode`	string	tidak	`free` (default) atau `recommendation` (tombol "Rekomendasi hari ini")
`context_article_id`	uuid atau null	tidak	diisi saat dibuka dari tombol "Tanya asisten soal ini"
`tasks`	array string	tidak	maksimal 10 item, tiap item maksimal 100 karakter; hanya dipakai pada mode `recommendation`

FE tidak mengirim riwayat chat maupun data check-in. Server mengambil sendiri 10 pesan terakhir, check-in hari ini, dan ringkasan 7 hari dari database, sehingga data tidak bisa dimanipulasi dari browser.

Response 200

```
{
  "user_message_id": "uuid",
  "reply": {
    "id": "uuid",
    "text": "Teks balasan asisten",
    "card": null,
    "sources": [
      { "title": "Judul artikel", "article_id": "uuid", "url": null }
    ],
    "suggested_action": null
  },
  "flag": { "level": "none", "banner": null },
  "usage": { "remaining_this_hour": 17 }
}
```

Field	Aturan
`reply.text`	string, selalu ada
`reply.card`	null, atau objek Rekomendasi (6.3); hanya pada mode `recommendation`
`reply.sources`	array, boleh kosong; `article_id` atau `url` boleh null
`reply.suggested_action`	null, atau `open_checkin` jika mode `recommendation` tetapi check-in hari ini belum ada (`card` null)
`flag.level`	salah satu dari `none`, `warning`, `severe`, `crisis`
`flag.banner`	null, atau `{ type, title, body }` dengan `type` `see_doctor` atau `crisis`
`usage.remaining_this_hour`	integer, sisa pesan pada jam berjalan

6.2 Perilaku FE berdasarkan flag

`flag.level`	Banner	Perilaku FE
`none`	null	Tampilkan balasan biasa
`warning`	`see_doctor`	Balasan + banner lembut "sebaiknya periksa ke dokter"
`severe`	`see_doctor`	Balasan + banner merah dengan tombol "Siapkan ringkasan untuk dokter"
`crisis`	`crisis`	**LLM tidak dipanggil.** `reply.text` berisi pesan empatik tetap. FE mengganti input dengan kartu bantuan (kontak dari `src/config/crisis.js`, diisi setelah diverifikasi) dan tombol "Kembali"

Teks banner dan balasan krisis dikendalikan server agar seragam. Daftar kata pemicu dan ambangnya ada di PRD Bagian 8.3.

6.3 Objek `card` (Rekomendasi hari ini)

```
{
  "beban": "ringan",
  "aktivitas": ["Jalan santai 20 menit", "Peregangan ringan", "Minum air
putih cukup"],
  "tips_istirahat": "Usahakan tidur sebelum jam 23.00.",
  "prioritas_tugas": ["Selesaikan laporan dulu", "Tunda rapat tidak penting"]
}
```

`aktivitas` selalu 3 item. `prioritas_tugas` bernilai null jika tidak ada `tasks` di request.

6.4 Contoh respons (fixture untuk mock FE)

FE menaruhnya di `src/mocks/chat.js` supaya UI bisa dibangun sebelum backend siap.

Respons biasa

```
{
  "user_message_id": "msg-user-1",
  "reply": {
    "id": "msg-model-1",
    "text": "Wajar kalau lelah, apalagi tidurmu kurang semalam. Coba kurangi
aktivitas berat hari ini dan istirahat cukup.",
    "card": null,
    "sources": [],
    "suggested_action": null
  },
  "flag": { "level": "none", "banner": null },
  "usage": { "remaining_this_hour": 19 }
}
```

Respons rekomendasi

```
{
  "user_message_id": "msg-user-2",
  "reply": {
    "id": "msg-model-2",
    "text": "Dari check-in hari ini, ini saran untukmu.",
    "card": {
      "beban": "ringan",
      "aktivitas": ["Jalan santai 20 menit", "Peregangan ringan", "Minum air
putih cukup"],
      "tips_istirahat": "Usahakan tidur sebelum jam 23.00.",
      "prioritas_tugas": null
    },
    "sources": [],
    "suggested_action": null
  },
  "flag": { "level": "none", "banner": null },
  "usage": { "remaining_this_hour": 18 }
}
```

Respons krisis

```
{
  "user_message_id": "msg-user-3",
  "reply": {
    "id": "msg-model-3",
    "text": "Terima kasih sudah berbagi. Kamu tidak sendirian. Yuk bicara
dengan tenaga profesional atau orang yang kamu percaya sekarang.",
    "card": null,
    "sources": [],
    "suggested_action": null
  },
  "flag": {
    "level": "crisis",
    "banner": {
      "type": "crisis",
      "title": "Kamu tidak sendirian",
      "body": "Hubungi tenaga profesional atau orang terdekat sekarang."
    }
  },
  "usage": { "remaining_this_hour": 17 }
}
```

6.5 Riwayat chat (Jalur A, hanya baca)

```
await supabase.from('chat_messages')
  .select('id, role, content, meta, flag_level, created_at')
  .order('created_at', { ascending: false })
  .limit(30);
// Halaman berikutnya: tambahkan .lt('created_at', createdAtTerlama)
```

FE membalik urutan untuk tampilan. Kolom `meta` berisi `{ card, sources }` untuk pesan `model`. **FE tidak pernah menulis ke `chat_messages`**; hanya server yang menulis (lihat Bagian 10).

6.6 Memanggil dari FE

```
const { data, error } = await supabase.functions.invoke('chat', {
  body: { message, mode: 'free' },
});

if (error) {
  const body = await error.context?.json?.().catch(() => null);
  const code = body?.error?.code ?? 'INTERNAL';
  // tangani sesuai tabel 2.1
}
```

6.7 Aturan server (untuk BE)

1. Verifikasi JWT, ambil profil; `consent_at` null menghasilkan 403.
2. Validasi body; tidak valid menghasilkan 400.
3. Rate limit: hitung pesan `role = user` milik pengguna dalam 1 jam terakhir dari `chat_messages`; batas 20, lebih dari itu 429.
4. Jalankan filter kata bahaya (kode biasa). Jika krisis: simpan pesan dan balasan tetap (`flag_level = crisis`), kembalikan, **tanpa memanggil LLM**.
5. Susun konteks (riwayat, check-in, ringkasan 7 hari, 1-3 artikel relevan) lalu panggil Gemini dengan timeout 20 detik. Jika gagal atau kuota habis, coba penyedia cadangan bila ada; tetap gagal menghasilkan 503 dan **tidak ada yang disimpan**, supaya retry tidak menggandakan pesan.
6. Mode `recommendation`: minta keluaran JSON terstruktur. Jika gagal di-parse, kembalikan teks biasa dengan `card` null.

7. Simpan pesan pengguna dan balasan (dengan `flag_level` dan `meta`), lalu kembalikan response.
8. Jangan mencatat isi pesan lengkap di log fungsi.

7. Edukasi (Jalur A)

```
// Daftar, dengan filter kategori dan pencarian opsional
let q = supabase.from('education_articles')
  .select('id, title, category, summary, source_name, source_url')
  .eq('published', true);
if (category) q = q.eq('category', category);
if (search) q = q.ilike('title', `%${search}%`);
const { data } = await q.order('title');

// Detail
await supabase.from('education_articles').select('*').eq('id', id).single();
```

Aturan konten: setiap artikel wajib memiliki `source_name`. Kolom `body` berformat Markdown sederhana (judul, paragraf, daftar, huruf tebal). FE merendernya dengan pustaka Markdown dan **tidak merender HTML mentah**.

8. Privasi dan Data Pengguna

8.1 Unduh data (dibuat di sisi FE)

FE menggabungkan hasil `select` dari `profiles`, `daily_checkins`, dan `chat_messages`, lalu mengunduh berkas `pcosmart-data.json`:

```
{
  "exported_at": "2026-11-10T08:00:00Z",
  "profile": { },
  "checkins": [ ],
  "chat_messages": [ ]
}
```

8.2 Hapus akun: `POST /functions/v1/delete-account`

Request:

```
{ "confirm": "HAPUS" }
```

Response 200:

```
{ "deleted": true }
```

Error: 400 `VALIDATION_ERROR` jika `confirm` bukan `HAPUS`, 401 jika belum login. Server menghapus pengguna di Auth dan seluruh data pengguna ikut terhapus lewat `on delete cascade`. Setelah sukses, FE memanggil `signOut()` dan mengarahkan ke halaman login.

9. Perhitungan di Frontend

Untuk MVP semua agregasi dihitung di FE dari data rentang check-in (maksimal 90 baris). Aturan berikut disepakati supaya Riwayat, Beranda, dan PDF menampilkan angka yang sama.

- **Episode haid:** rangkaian hari berurutan dengan `on_period = true`. Hari tanpa catatan dianggap tidak diketahui, bukan "tidak haid".
- **Panjang siklus:** selisih hari antara tanggal mulai dua episode haid berurutan. Rata-rata dan rentang (terpendek sampai terpanjang) dihitung dari siklus yang terdata. Minimal 2 episode untuk menampilkan angka; kurang dari itu tampilkan "Belum cukup data".
- **Gejala paling sering:** hitung kemunculan tiap slug dalam periode, urutkan menurun, tampilkan 5 teratas.
- **Tren energi, mood, dan tidur:** nilai per hari; hari tanpa data dilewati (bukan dihitung nol).
- **Dilarang:** menampilkan prediksi tanggal haid.
- Semua fungsi perhitungan ditaruh di `src/lib/stats.js` dan dipakai bersama oleh Riwayat, Beranda, dan PDF, disertai unit test sederhana.

Jika performa bermasalah, BE dapat menyediakan fungsi SQL (RPC) di versi berikutnya.

10. Perubahan Skema (Migration 002)

Kontrak ini mengharuskan perubahan berikut pada skema awal. BE menjalankannya dan menyimpannya di `supabase/migrations/002_contract.sql`. Jika ada data uji dengan `energy` atau `mood` kosong, hapus dulu.

```
-- Check-in: perketat aturan data
alter table daily_checkins alter column on_period set not null;
alter table daily_checkins alter column energy set not null;
alter table daily_checkins alter column mood set not null;
alter table daily_checkins add constraint sleep_hours_range
  check (sleep_hours between 0 and 24);
alter table daily_checkins add constraint intensity_needs_period
  check (on_period or period_intensity is null);

-- Chat: kolom tambahan dan hanya server yang boleh menulis
alter table chat_messages add column flag_level text not null default 'none'
  check (flag_level in ('none','warning','severe','crisis'));
alter table chat_messages add column meta jsonb;

drop policy "own chats" on chat_messages;
create policy "read own chats" on chat_messages for select
  using (auth.uid() = user_id);

create index chat_messages_user_time_idx
  on chat_messages (user_id, created_at desc);
```

Edge Function menulis ke `chat_messages` memakai service role (melewati RLS). Dengan begitu pengguna tidak bisa memalsukan pesan `model` atau mengubah riwayat chat dari browser.

11. Environment dan Secrets

Nama	Lokasi	Keterangan
`VITE_SUPABASE_URL`	`.env` FE (tidak di-commit)	URL project
`VITE_SUPABASE_ANON_KEY`	`.env` FE (tidak di-commit)	Anon atau publishable key; aman di browser selama RLS aktif
`GEMINI_API_KEY`	Supabase secrets	**Tidak pernah** di FE atau repo
`GEMINI_MODEL`	Supabase secrets	Nama model free tier yang dipakai; mudah diganti tanpa ubah kode

Nama	Lokasi	Keterangan
`GROQ_API_KEY`	Supabase secrets	Opsional, penyedia cadangan
`SUPABASE_SERVICE_ROLE_KEY`	Disediakan otomatis di Edge Functions	**Tidak pernah** dibagikan atau dipakai di FE

Repo hanya memuat `.env.example` tanpa nilai rahasia.

12. Checklist Pengujian Kontrak

- Daftar, login, onboarding: baris `profiles` terbentuk dengan `consent_at` terisi.
- Upsert check-in dua kali di tanggal yang sama menghasilkan satu baris.
- Pengguna B tidak bisa membaca atau mengubah data pengguna A (uji dengan dua akun).
- Insert langsung ke `chat_messages` dari FE ditolak setelah migration 002.
- `chat` mengembalikan 400 untuk pesan kosong atau lebih dari 1000 karakter.
- `chat` mengembalikan 401 tanpa login dan 403 jika `consent_at` kosong.
- Pesan ke-21 dalam satu jam mengembalikan 429 dengan `retry_after_seconds`.
- Pesan krisis mengembalikan `flag.level = crisis` tanpa memanggil Gemini (cek di log dan kuota).
- Gemini dimatikan atau key salah mengembalikan 503 dan tidak ada baris yang tersimpan.
- Mode `recommendation` tanpa check-in hari ini mengembalikan `suggested_action = open_checkin`.
- `delete-account` menghapus seluruh data pengguna dan pengguna tidak bisa login lagi.
- Pemanggilan dari domain deploy FE berhasil (CORS) dan tidak ada secret di bundle FE.

13. Aturan Perubahan dan Konsistensi Tim

- Versi kontrak saat ini **1.0**. Perubahan yang merusak (menghapus atau mengganti nama field, mengubah enum) harus dibicarakan di sync sebelum merge dan menaikkan versi minor.

- Perubahan dilakukan lewat PR yang mengedit file ini di repo (`docs/api-contract.md`), berlabel `contract-change`, direview minimal satu orang FE dan satu orang BE.
- BE mengumumkan di grup begitu perubahan ter-deploy; FE memperbarui mock.
- Penamaan: database dan JSON `snake_case`, variabel JS `camelCase`, komponen React `PascalCase`, branch `feat/nama-fitur`.
- Catat keputusan penting (apa, kenapa, siapa, kapan) satu baris per keputusan di `docs/decisions.md`.
- Pembagian peran dokumen: **PRD** menjelaskan apa yang dibangun, **kontrak ini** menjelaskan bagaimana FE dan BE berbicara. Jika keduanya bertentangan, bahas dulu lalu perbarui keduanya.